ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Benshaw RSi H2 Series Multi-Purpose Industrial Variable Frequency Drive · Component type: **Embedded Device (EDR) - variable frequency drive (VFD)** · Target SL = SL 3

Where to work	Native config at the **LCD plain-English keypad** (parameter groups; the **COMMUNICATION (COM) group** holds station address, baud, protocol, and timeout; the **command-source / reference-source** parameters must be set to **Network** before the drive obeys fieldbus run/reference). Comms hardware: on-board **RS-485** card = **Modbus RTU / BACnet MS-TP / Metasys N2**; optional **EtherNet/IP & Modbus-TCP** card; optional Extended I/O. Confirm the exact **parameter-access lock / password** and COM parameter numbers against the H2 manual **890053-00-02** on the unit.
Ports / paths	On-board **RS-485**: **Modbus RTU**, **BACnet MS-TP**, **Metasys N2**. Optional Ethernet card: **Modbus TCP 502**, **EtherNet/IP TCP 44818 / UDP 2222**, **BACnet/IP UDP 47808**. Keypad (LCD) + parameter groups; STO (safe torque off) option; digital/analog I/O. No TLS on the drive/fieldbus (unauthenticated cleartext).
Notes / lifecycle	Benshaw RSi H2 Series general-purpose LV VFD. No multi-user accounts, no comms encryption - native controls are the **keypad parameter-access lock/password**, the **command-source = Network** gating (the drive ignores network commands unless enabled), and **physical** control; integrity/confidentiality are by segmentation. Confirm drive firmware + comm-card type/firmware; track Benshaw / CISA advisories. Two safety anchors: (1) STO / comm-loss fault action must give a defined safe stop independent of the network; (2) physical cabinet control.
How to read	Default read-only (record COM + lock parameters from the keypad; read-only Modbus reads; fault-log review). Each row = native keypad step-by-step + command-level external-tool validation + pass. Write/exploit tools = isolated bench + written authorization (a mis-set drive can start a motor). Several rows are Compensating / verify-against-manual.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 1.1	Human user identification & auth	The drive has **no user accounts**. Local access is the **keypad**; enable the drive's **parameter-access lock / password** (confirm the exact parameter against manual 890053-00-02) so parameter/config changes require it. The **Modbus / EtherNet-IP** path has **no authentication**; compensate by requiring **command-source = Network** (so the drive ignores unsolicited network commands unless enabled) + segmentation + physical control. **Test:** at the keypad, attempt a parameter change -> password required (if enabled); confirm the drive does not obey network run/reference unless command-source = Network. **Ext. tools:** Keypad (lock/password + command-source review per manual); confirm only the authorized master polls the RS-485/Ethernet.	Keypad password enabled + command-source gating + physical/segmentation; unauthenticated fieldbus compensated.	EDR - no device auth; compensating.
SR/CR 1.2	Device & software-process I&A;	Fieldbus is **unauthenticated**; the drive is identified by its **Modbus station address** / BACnet instance / EtherNet-IP node/IP (COM group). Bind identity by a single known master + segmentation; document the address and the authorized master. **Test:** from a non-authorized master, poll the drive -> blocked by segmentation. **Ext. tools:** `modpoll -m rtu -a -b -1 /dev/ttyUSB0` or `modpoll -m tcp -a` (read-only); `nmap --script enip-info -p 44818 .`	Drive identified by station address/IP; single authorized master; unauthenticated protocol compensated.	No fieldbus auth - Compensating.
SR/CR 1.3	Account management	No user accounts; manage the **keypad password** as a controlled secret, the config-tool/host access, and (if the Ethernet card has a web page) its credentials - change any default. Keep custody of the parameter backup. **Ext. tools:** Password custody record; host/config-tool review; Ethernet-card web (change defaults); backup custody.	Keypad password + host + card credentials controlled; defaults changed; backup protected.	
SR/CR 1.4	Identifier management	Confirm a unique **Modbus station address** / BACnet instance / EtherNet-IP IP and a unique drive identity (model + serial); no reuse on the loop/segment. **Ext. tools:** Keypad (COM address); `modpoll` scan for collisions; asset register.	Unique drive address/identity; no reuse.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 1.5 / 1.7	Authenticator management & strength	Set the keypad **parameter-access password** to a non-default value and control it; if the Ethernet card has a web login, set a strong password. Standard drive password policy is basic - document and compensate. **Ext. tools:** Keypad (password non-default per manual); Ethernet-card web password; document policy.	Non-default keypad password (+ card credentials); policy documented + compensated.	Basic policy - Partial.
SR/CR 1.6	Wireless access management	**N/A.** Wired drive with no native wireless interface (unless a wireless keypad/option is fitted - then govern it). **Ext. tools:** Confirm no wireless option fitted.	N/A - justification recorded (wired device).	N/A
SR/CR 1.8 / 1.9	PKI certificates & key strength	**N/A / limited at device.** No TLS/PKI on the drive or fieldbus (Modbus/EtherNet-IP unauthenticated; any card web is HTTP). Record N/A; provide confidentiality/integrity by segmentation. **Ext. tools:** Confirm no device certificate/TLS; Wireshark (cleartext fieldbus / HTTP).	N/A/limited device PKI; compensating segmentation.	N/A/Partial.
SR/CR 1.10	Authenticator feedback	Confirm the keypad password entry is not shown in clear on the LCD (verify against the manual). **Ext. tools:** Visual keypad check.	Authenticator obscured during entry.	Verify.
SR/CR 1.11	Unsuccessful login attempts	The keypad password has **no lockout counter** and the fieldbus does not lock out - compensate with physical control + segmentation + monitoring of anomalous writes at the master/IDS. **Ext. tools:** Physical control; Modbus/OT IDS on the segment for anomalous writes.	No native lockout; physical + segmentation + monitoring compensate.	Legacy limitation.
SR/CR 1.12	System use notification	**N/A at device** (no login/display banner). Apply an approved-use placard on the drive/cabinet (compensating). **Ext. tools:** Physical placard review.	Use notice via cabinet placard (compensating).	Compensating.
SR/CR 1.13	Access via untrusted networks	Segment the drive into a motor-control cell; keep the RS-485 loop local and firewall the Ethernet card (502/44818/2222/47808); no fieldbus from untrusted networks; remote config via VPN/jump host. **Test:** from an untrusted VLAN, reach the drive 502/44818 -> must fail. **Ext. tools:** `nmap -Pn -p 502,44818,2222,47808` from the untrusted side (expect filtered); firewall review.	Drive unreachable from untrusted networks; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 2.1	Authorization enforcement	No role model. Authorization = the **keypad parameter-access lock** (gating parameter changes) plus the **command-source / reference-source** selection (which source may start/stop and set speed) and read-only vs read/write Modbus. Confirm which registers are writable and restrict writes at the master. **Test:** with the lock on, attempt a parameter change -> denied; confirm a non-selected source cannot command run. **Ext. tools:** Keypad (lock + command-source review); `modpoll` read-back to confirm write scope (authorized/isolated).	Least privilege via keypad lock + command-source; unauthorized config/command denied.	No device roles - Compensating.
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control any laptop/keypad-copy device + USB-RS485 adapter used for config; only authorized firmware/parameter files loaded; physical port control. **Ext. tools:** Host/media control; confirm parameter-file provenance; physical inspection.	Engineering media controlled; only authorized artifacts loaded.	
SR/CR 2.4 (+ EDR 2.4)	Mobile code	**N/A.** Fixed-function drive firmware; no general-purpose or downloadable code executes on the drive. **Ext. tools:** Confirm fixed-function device (no code-load path beyond firmware).	N/A - no mobile-code capability (fixed firmware).	EDR-specific / N/A.
SR/CR 2.5	Session lock	Confirm the keypad reverts to the run display after inactivity (re-entry of the password required for changes); no fieldbus session to lock. **Ext. tools:** Keypad inactivity behavior (per manual).	Keypad reverts/locks on inactivity (if supported).	Verify.
SR/CR 2.6 / 2.7	Remote session termination & concurrency	Confirm a single command-source is active so simultaneous conflicting control is prevented, and the fieldbus bounds concurrent connections; RS-485 is single-master. **Ext. tools:** Keypad (command-source); Wireshark (connection count / single master).	Single command-source; concurrency bounded.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 2.8 / 2.12	Auditable events & non-repudiation	The drive has a **fault/trip history** but no security-audit/syslog. Capture parameter-change attribution via a keypad/tool **parameter backup compare**, the controlling PLC/SCADA, and a Modbus/EtherNet-IP-aware OT IDS; forward off-device to the SIEM. **Ext. tools:** Keypad/tool (fault history + param compare); PLC/SCADA change log; OT IDS + SIEM.	Config changes attributable via backup-compare + PLC; drive events captured by IDS.	No native syslog - Compensating.
SR/CR 2.9 / 2.10	Audit storage capacity & failure handling	Because security logging is off-device, confirm the PLC/SCADA/SIEM are sized/retained and alert on collection or drive comms-loss failure so events are not silently lost. **Ext. tools:** SCADA/SIEM retention + comms-loss alarm review.	Off-device logs sized/retained; audit-failure/comms-loss alerting defined.	Compensating.
SR/CR 2.11	Timestamps	The drive fault history may be relative to power-up; confirm the controlling PLC/SCADA is NTP-synced so drive events correlate. **Ext. tools:** Keypad (fault-history time base); PLC/SCADA NTP check.	Correlatable time via the synced PLC/SCADA.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: locked cabinet; secure the **keypad** (and its parameter-copy function), the **RS-485 / Ethernet** terminals, the **STO** terminals, and any USB/option port; shut/disable unused I/O. **Ext. tools:** Physical inspection (cabinet, keypad, RS-485/STO terminals, unused ports).	Physical/diagnostic interfaces controlled; cabinet locked.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 3.1 / 4.1	Communication integrity & confidentiality	Modbus RTU / BACnet / EtherNet-IP / Modbus TCP are **unauthenticated cleartext** with no TLS - integrity/confidentiality come from **containment**: keep the RS-485 loop local and the Ethernet card in a segmented cell; no cleartext control crosses a zone boundary uncontrolled. **Test:** confirm fieldbus traffic stays in-zone. **Ext. tools:** Serial capture / `modpoll` (cleartext confirm); Wireshark (`modbus || enip`, in-zone only); firewall review.	Drive comms contained/segmented; no uncontrolled cleartext (no native crypto).	No crypto - Compensating.
EDR 3.2	Protection from malicious code (component)	Confirm only Benshaw firmware runs (fixed-function; no field code path beyond firmware). Load firmware only from Benshaw and verify provenance; restrict who can update; track Benshaw / CISA advisories. **Ext. tools:** Keypad/tool (firmware version + provenance); Benshaw advisory review.	Only vendor firmware runs; provenance verified; update restricted.	EDR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: keypad lock, COM group (address/baud/protocol/timeout), command-source, writable-register restriction, Ethernet-card exposure, and firmware, against the recorded baseline; read the parameters back. **Ext. tools:** Keypad review + `modpoll` read-back vs baseline; `nmap -p 502,44818 .`	Security/config settings match the recorded baseline after change.	
SR/CR 3.4	Software & information integrity	The "config" is the **parameter set** - record it as a baseline (keypad parameter save / tool export) and detect drift by periodic read-back; the keypad lock prevents unauthorized change; unauthorized parameter change is the key integrity risk (can start a motor / change speed limits). **Ext. tools:** Parameter backup (keypad/tool); periodic `modpoll` read-back compare for drift.	Parameter baseline recorded; drift detected; unauthorized change prevented (lock).	
SR/CR 3.5	Input validation	Confirm the drive tolerates malformed **Modbus / EtherNet-IP** frames without faulting or an unexpected trip/start. **ISOLATED bench only:** fuzz the fieldbus on a bench drive (motor uncoupled) and watch the fault history + output. **Ext. tools:** Fieldbus fuzzer (`boofuzz` Modbus/EtherNet-IP) on a bench drive; watch fault/trip + STO.	No fault/unexpected start on malformed input.	Do NOT fuzz an in-service drive.
SR/CR 3.6	Deterministic output	**Safety-critical row.** Verify the **STO (safe torque off)** function (if fitted) removes torque independently of comms, and that the configured **fault-stop mode** (coast/ramp) and the **network comm-loss fault action** drive a defined safe stop (not a runaway). **Test:** ISOLATED: trigger STO / simulate network comm loss -> drive removes torque / performs the configured safe stop. **Ext. tools:** STO bench test; keypad (comm-loss fault action / stop mode review per manual).	STO removes torque independently of comms; comm loss drives a defined safe stop.	Safety-critical.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 3.7	Error handling	Confirm graceful fault handling: the drive trips/stops safely, the fault history records the cause, and any **auto-restart** is reviewed (no unsafe auto-restart) with no info leak. **Ext. tools:** Keypad (fault history + auto-restart config review).	Graceful fault handling; no unsafe auto-restart or info leak.	
SR/CR 3.8	Session integrity	**N/A / limited.** No authenticated/encrypted fieldbus session; integrity by containment. Record N/A + compensating segmentation. **Ext. tools:** Confirm no session security; segmentation review.	N/A/limited at device; compensating segmentation recorded.	N/A/Partial.
SR/CR 3.9	Protection of audit information	Since audit is off-device, protect the PLC/SCADA/IDS/SIEM store and restrict who can read/clear it. **Ext. tools:** SCADA/SIEM access review.	Off-device audit records protected from unauthorized access.	
EDR 3.10	Support for updates	Update firmware via the Benshaw tool/keypad with firmware from Benshaw; verify version/provenance; plan in a maintenance window with a rollback/parameter-restore plan. **Ext. tools:** Keypad/tool (update flow + provenance); Benshaw firmware; rollback plan.	Controlled updates from a verified source, with rollback.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Keep the drive in a locked/sealed cabinet; control the keypad, RS-485/Ethernet, and STO terminals; config drift is visible via parameter compare. **Ext. tools:** Physical inspection (cabinet/seal, keypad, terminals); parameter compare.	Cabinet secured; interfaces controlled; drift detectable.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	**Partial/N-A at device.** No documented signed-firmware supplier root of trust on the H2. Record the gap; compensate with firmware-provenance discipline (3.10), update restriction, physical control, and segmentation. **Ext. tools:** Confirm firmware provenance/signing level with Benshaw; update-restriction review.	Supplier trust via provenance; attestation gap recorded.	EDR-specific/Partial.
EDR 3.13	Provisioning asset-owner roots of trust	**N/A at device.** No asset-owner certificate provisioning (no PKI). Record the gap; asset-owner trust is enforced at the network/PLC + physical + the keypad password the owner controls. **Ext. tools:** Confirm no cert provisioning; segmentation + password custody review.	No asset-owner RoT at device; network/keypad controls compensate.	EDR-specific / N/A.
EDR 3.14	Integrity of the boot process	**N/A at device.** No published secure-boot attestation on the H2. Record the gap; mitigate via firmware provenance (3.10), update restriction, physical control, and monitoring. **Ext. tools:** Confirm boot-integrity level with Benshaw; firmware version review.	Boot-integrity gap recorded; compensating controls in place.	EDR-specific / N/A.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 4.2	Information persistence	On decommission/repurpose, **restore factory defaults** (clear parameters), remove/clear any parameter-copy keypad, and destroy/secure parameter backups so site configuration is not recoverable (the drive holds little sensitive data - parameters + address). **Ext. tools:** Keypad (restore defaults); sanitize parameter-copy/backups.	Parameters/address purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	**N/A / limited.** No comms crypto on the drive. Rely on segmentation; where confidentiality across the fieldbus is required, add an external secure layer. **Ext. tools:** Confirm no comms crypto; segmentation review.	No comms crypto - compensating segmentation.	N/A/Partial.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 5.1 / 5.2	Network segmentation & zone boundary	Confirm the drive sits in a segmented motor-control cell; only the intended PLC/master reaches the RS-485 and the Ethernet card; the **Ethernet card is the network exposure point** - firewall it (502/44818/2222/47808); no flat convergence with IT. **Ext. tools:** `nmap -p 502,44818,2222,47808` per zone; firewall rule review.	Drive in a segmented cell; Ethernet card firewalled; only required flows cross.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Motor drive with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR/CR 5.4	Application partitioning	**N/A.** Single-function drive; nothing to partition (keep any STO/safety wiring separate from control). **Ext. tools:** Confirm single-function device.	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 6.1 / 6.2	Audit log accessibility & continuous monitoring	Confirm the drive **fault history** is readable via keypad/tool/fieldbus and that a passive **Modbus/EtherNet-IP-aware OT IDS** on the cell + the PLC/SCADA capture drive events (trips, comm loss, param writes) and forward to the SIEM. **Ext. tools:** Keypad/tool (fault-history read); PLC/SCADA; OT IDS + SIEM.	Drive events accessible and monitored off-device in near-real-time.	Compensating.

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 7.1	Denial-of-service protection	Confirm the drive is resilient: a fieldbus flood must not cause a runaway - verify the **network comm-loss fault action** drives a safe stop and that **STO** (if fitted) is independent of comms; firewall/rate-limit the Ethernet card. **Ext. tools:** ISOLATED bench: fieldbus storm (`hping3 --flood -p 502 `); confirm comm-loss safe stop + STO independence.	Comm loss drives a safe stop; STO comms-independent; card rate-limited.	Safety-relevant.
SR/CR 7.2	Resource management	Confirm bounded resources: the drive keeps controlling the motor under fieldbus load and one service cannot starve control. **Ext. tools:** Bench load test; drive diagnostics.	Resources bounded; no comms-induced loss of motor control.	
SR/CR 7.3 / 7.4	Backup & recovery	Record the full **parameter set + COM/address** (keypad save / tool export) so a replacement can be reconfigured; hold a spare drive and test its configuration on the bench. **Ext. tools:** Parameter backup (keypad/tool); spare-drive config + bench validation.	Config recorded for rebuild; spare validated.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6 / 7.7	Network & security settings + least functionality	Harden: enable the keypad parameter lock/password, set **command-source = Network** only where required, use a single protocol on the RS-485 (Modbus **or** BACnet/N2), set a non-default station address, restrict writes at the master, disable/limit the Ethernet card if unused, and physically secure the unit. **Ext. tools:** Keypad (lock/COM/command-source); master write ACL; `nmap -p 502,44818,47808 .`	Least functionality: one protocol, keypad lock, non-default address, restricted writes.	
SR/CR 7.8	Component inventory	Inventory the drive (H2 model + rating, firmware), the comm-card type (RS-485 Modbus/BACnet/N2, or EtherNet-IP/Modbus-TCP) + firmware, and any STO/option, so vulnerabilities track against Benshaw / CISA advisories. **Ext. tools:** Keypad/nameplate (model/firmware/card); asset register; Benshaw / CISA advisory check.	Accurate drive/card/firmware inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
LCD keypad / H2 manual 890053-00-02	Native config, lock & COM review (most FRs)	Record/set the parameter-access lock/password, the COMMUNICATION group (address/baud/protocol/timeout), the command-source/reference-source, and the fault history; confirm exact parameter numbers + lock behavior against the H2 instruction manual.	Read-only; authorized; record baseline.
Benshaw config tool / keypad parameter copy	Parameter backup, compare & firmware (3.3, 3.4, 7.3)	Export/back up the parameter set; compare to baseline for drift; manage firmware from Benshaw.	Authorized; back up before changes.
modpoll / mbpoll (RS-485 or Ethernet card)	Read-back, address & write-scope (1.2, 2.1, 3.3, 3.4)	`modpoll -m rtu -a -b -1 /dev/ttyUSB0` or `modpoll -m tcp -a` ; read status; confirm which registers are writable (authorized/isolated).	Read-only on production; writes isolated.
nmap	Ethernet-card exposure & segmentation (1.13, 5.x, 7.x)	`nmap -Pn -p 502,44818,2222,47808` ; `nmap --script enip-info -p 44818` ; scan per zone.	Read-only; authorized.
Serial analyzer / Wireshark	Comms integrity & containment (1.2, 3.1)	Capture the RS-485 Modbus/BACnet (USB-RS485 tap) or `modbus || enip` on the card; confirm cleartext stays in-zone.	Passive; tap/SPAN only.
Fieldbus fuzzer (isolated)	Input validation (3.5)	`boofuzz` Modbus/EtherNet-IP to a BENCH drive (motor uncoupled); watch fault history + STO/output.	ISOLATED bench; written authorization.
STO bench test	Deterministic/fail-safe output & DoS (3.6, 7.1)	Trigger STO / simulate network comm loss on a bench drive; confirm torque removal / configured safe stop independent of comms.	ISOLATED bench; safety verification.
Passive OT IDS + Benshaw/CISA advisories	Monitoring & vuln tracking (2.8, 6.x, 7.8)	Modbus/EtherNet-IP-aware IDS on the cell for drive events/anomalous writes; track Benshaw / CISA advisories.	Passive; coordinate with SOC.

Controlled - Project Use · Independent Assurance Authority · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.